

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check 12.2.2 + Maven) · Generated 2026-07-13 · Source: `pom.xml` @ `61ed8c3`

Summary

Metric	Count
Dependencies scanned	23 (8 direct, 15 transitive)
Total CVEs found	75
CRITICAL CVEs	16
HIGH CVEs	46
MEDIUM CVEs	12
LOW CVEs	1
Outdated dependencies	8
License violations	1 (+ 1 WARN)
Supply-chain alerts	2

Known-vulnerable dependencies

Dependency	Version	Top CVE	CVSS	Severity	Fix applied
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.25.4
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.25.4
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.18.8
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.0-jre
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	com.mysql:mysql-connector-j:8.2.0
com.google.protobuf:protobuf-java (transitive)	3.19.4	CVE-2024-7254	7.5	HIGH	3.25.5 (pinned)
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.14.0
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.18.0
com.fasterxml.jackson.core:jackson-annotations (transitive)	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.18.8 (transitive of jackson-databind)

Verified-fixed CVEs (post-remediation re-scan)

All CVEs above — 75 findings across the 9 dependencies in this table — were confirmed **cleared** by fresh OWASP Dependency-Check and Grype/SBOM re-scans (Stage 4 gate on PR #77). Note the scanner's initial `fix_version` suggestion was insufficient for three dependencies and the applied fix went further:

- `jackson-databind` : initial suggestion 2.9.10.8 still left CVE-2023-35116 (needs 2.16.0); the Stage 4 Gripe re-scan then found 2.16.0 still vulnerable to GHSA-rmj7-2vxq-3g9f, GHSA-j3rv-43j4-c7qm (both High) and GHSA-hgj6-7826-r7m5 (Medium) — fixed only in **2.18.8**.
- `log4j-core` / `log4j-api` : initial suggestion 2.17.1 still left 2025/2026-dated CVEs unresolved (CVE-2026-34477, CVE-2026-34479, CVE-2026-34480, CVE-2025-68161); fixed in 2.25.4.
- `mysql:mysql-connector-java` : the old coordinate tops out at 8.0.33 (still vulnerable to CVE-2023-22102); Oracle's relocation to `com.mysql:mysql-connector-j` had to be followed to 8.2.0.

A Gripe-only Medium finding (GHSA-5jmj-h7xm-6q6v on `jackson-databind`, no upstream fix yet available) remains and is non-blocking per the Stage 4 gate policy (Medium/Low are logged, not gating).

License issues

Dependency	License	Status
mysql:mysql-connector-java:8.0.30	GPL-2.0 with FOSS exception	VIOLATION
org.checkerframework:checker-compat-qual:2.0.0 (transitive)	GPL-2.0-classpath-exception / MIT (dual)	WARN (MIT option acceptable)

The GPL-2.0 violation is **not** resolved by the CVE fix above — Oracle's `com.mysql:mysql-connector-j` carries the same license. Tracked as a separate human follow-up (see PR for issue link).

Supply-chain alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` impersonates the legitimate `com.fasterxml.jackson.core` (missing "er" in the groupId); the coordinate does not exist on Maven Central and was only reachable via the untrusted HTTP mirror below. **Removed** in this run's remediation.

HIGH — Untrusted repository. `http://insecure-mirror.example.net/maven2` is a plain-HTTP Maven repository (MITM artifact-injection risk), still declared in `pom.xml` . Not removed by this run — no dependency currently resolves through it, but it remains a standing risk; see the supply-chain audit follow-up.